

Incident and Response Lab 1: Virtual Machine Brute Forcing

Note: "**windows-target-1**" might be called "**windows-target-**" when you query for it. MDE will sometimes cut the name off if it's too long.

Pre-Lab

If you don't already have a Virtual Machine created and onboarded to Defender for Endpoint, consider doing these things now:

- Skool: [Azure Virtual Machine Overview \(How to Create a Virtual Machine\)](#).
- Skool: [Onboarding a VM to MDE \(Ensuring logs are being brought into the platform\)](#).

Explanation

When entities (local or remote users, usually) attempt to log into a virtual machine, a log will be created on the local machine and then forwarded to [Microsoft Defender for Endpoint](#) under the **DeviceLogonEvents** table. These logs are then forwarded to the Log Analytics Workspace being used by **Microsoft Sentinel**, our **SIEM**. Within **Sentinel**, we will define an alert to trigger when the same entity fails to log into the same VM a given number of times within a certain time period. (i.e. 10 failed logons or more per 5 hours).

Part 1: Create Alert Rule (Brute Force Attempt Detection)

Design a Sentinel Scheduled Query Rule within Log Analytics that will discover when the same remote IP address has failed to log in to the same local host (Azure VM) 10 times or more within the last 5 hours

Hint: Use the **DeviceLogonEvents** table.

DeviceLogonEvents

| where TimeGenerated > ago(23h) // 23h was used to identify high "LogonFailed" from suspicious remote IP addresses. Use 4h or 5h for scheduling.

| where ActionType == "LogonFailed"

| summarize NumberofFailures = count() by RemoteIP, ActionType, DeviceName

| where NumberofFailures >= 50 //choose a number of logon failures according to the company's policy

Query Run query Create summary rule Create detection rule 100,000 (Default) Set in query

Export Query history Getting started

Export 14 items Search 00:01.115 Low

Filters: Add filter

RemoteIP	ActionType	DeviceName	NumberOfFailures
> (0) 10.0.0.8	LogonFailed	test-win-server	91
>	LogonFailed	test-win-server	86
> (0) 80.94.95.83	LogonFailed	ty-win-vm	70
> (0) 10.0.0.8	LogonFailed	noah-linux-program...	180
> (0) 141.11.88.4	LogonFailed	noah-linux-program...	91
> (0) 10.0.0.8	LogonFailed	vm-final-lab-mi	60
> (0) 176.65.139.248	LogonFailed	linux-meg.n5qym3dq...	89
> (0) 27.28.228.94	LogonFailed	litefoot	100
> (0) 45.227.254.151	LogonFailed	faint-advantage	75
>	LogonFailed	win-final-lab-a	57
> (0) 125.23.89.138	LogonFailed	matt-vm-mde	58
> (0) 10.0.0.8	LogonFailed	vm-final-lab-ja	216

Once your query is good, create the Schedule Query Rule in: **Sentinel** → **Analytics** → **Schedule Query Rule**

Analytics Rule Settings:

- Enable the Rule
- **Use ChatGPT to set Mitre ATT&CK Framework Categories based on the query** "for the KQL query listed above, please tell me the Mitre ATT&CK framework categorization and please just list them in a simple list": 1. **Tactic: Initial Access** [Technique: Brute Force (T1110)]; 2. **Tactic: Credential Access** [Technique: Credential Stuffing (T1071)]; 3. **Tactic: Discovery** [Technique: Account Discovery (T1087)]
- Run query every 4 hours
- Lookup data for last 5 hours (can define in query)
- Stop running query after alert is generated == Yes
- Configure Entity Mappings for the Remote IP and DeviceName
- Automatically create an Incident if the rule is triggered
- Group all alerts into a single Incident per 24 hours
- Stop running query after alert is generated (24 hours)

Part 2: Trigger Alert to Create Incident

Trigger the rule manually to create an incident. If the necessary logs to trigger the rule don't exist, create the logs by failing to log into the machine an adequate number of times.

Don't get confused between the [Configuration → Analytics] and [Threat Management → Incidents] sections.

Part 3: Work Incident

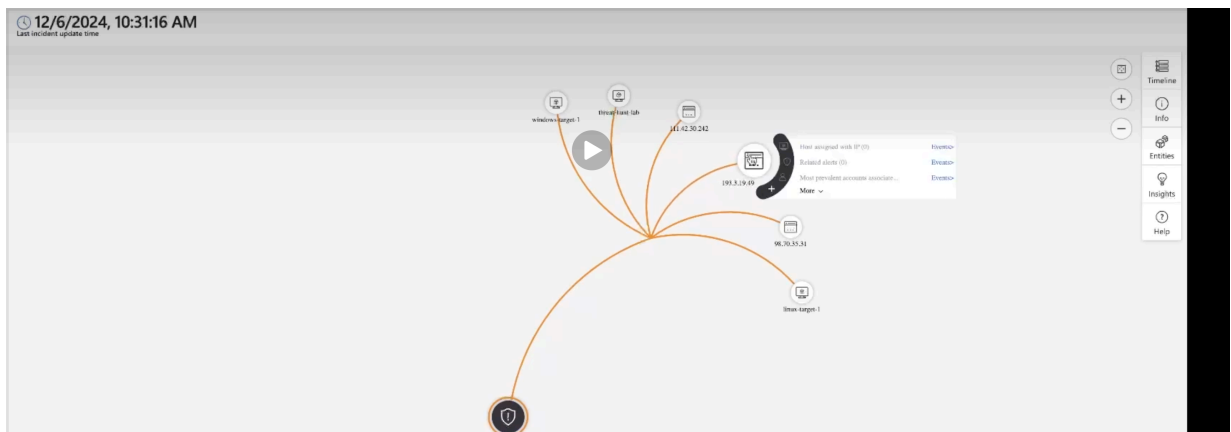
Work your incident to completion and close it out, in accordance with the NIST 800-61: Incident Response Lifecycle

Preparation

- Document roles, responsibilities, and procedures.
- Ensure tools, systems, and training are in place.

Detection and Analysis

- Identify and validate the incident.
 - Observe the incident and assign it to yourself, set the status to Active
 - Investigate the Incident by **Actions** → **Investigate** (sometimes takes time for entities to appear)



- Gather relevant evidence and assess impact.
 - Observe the different entity mappings and take notes:
 - ♦ The **Brute Force Detection - Instructor's Demo** incident was triggered from 6 different IP addresses against 2 different hosts.
<Lists Hosts and IPs>
 - Check to make sure none of the IP addresses attempting to brute force the machine actually logged in. (Hint: It's possible to build this into the query to only trigger for apparent successful brute forces)
 - **DeviceLogonEvents** //using the 3 public IP addresses with highest "LogonFailed" within the last 23 hours not related to the **Brute Force Detection - Instructor's Demo** incident.
 - | where RemoteIP in ("27.28.228.94", "141.11.88.4", "176.65.139.248")
 - | where ActionType != "LogonFailed"
 - ♦ Record Finding: **No successful Logons**

Query Run query Create summary rule Create detection rule 100,000 (Default) Last 7 days

1 Your query contains UEBA-eligible tables. Consider joining with the [Anomalies](#) table to enrich your analysis with behavioral insights. Don't want to see it again

```

1 DeviceLogonEvents //using the 3 public IP addresses with highest "LogonFailed"
2 | where RemoteIP in ("27.28.228.94", "141.11.88.4", "176.65.139.248")
3 | where ActionType != "LogonFailed"

```

Results Query history Getting started

Export Show empty columns 0 items Search 00:00.823 Low Grid Table Download Refresh

Filters: Add filter

No results found in the specified time frame.

Containment, Eradication, and Recovery

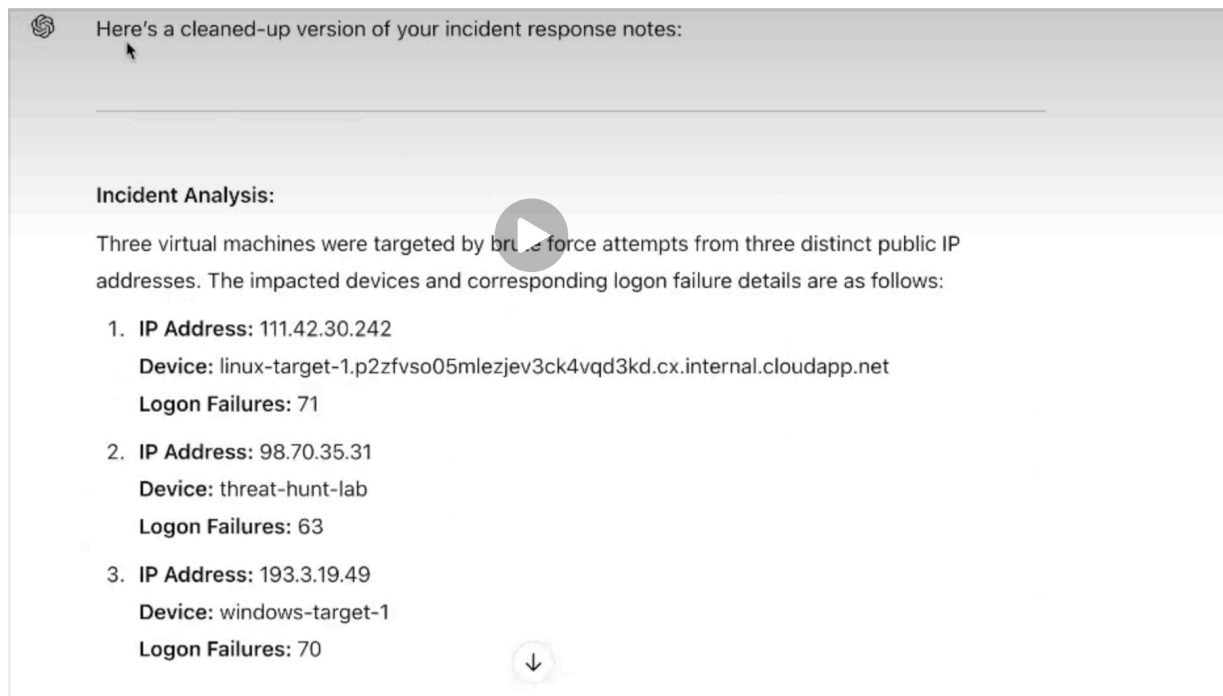
- Isolate affected systems to prevent further damage: **Two options:**
Isolate and/or Run Antivirus Scan in Defender-Assets-Devices
 - In real life if this was a serious threat, we would isolate your machine with Defender for Endpoint
 - Conduct an AV scan

KQL Query Spoiler

- For the lab, create or update the Network Security Group (NSG) attached to your Virtual Machine to prevent any traffic except your local PC from reaching the VM, and record in your notes:
 - NSG was locked down to prevent inbound RDP attempts from the public internet **EXCEPT FROM MY IP ADDRESSES FROM HOME OR FROM MY MOBILE DEVICES**
 - Corporate policy was proposed to require this for all VMs going forward. (this can be done with Azure Policy)
- Remove the threat and restore systems to normal.
 - Brute force was not successful, so no threats related to this incident.

Post-Incident Activities

- Document findings and lessons learned. Both were given to ChatGPT to summarize.
 - Record your notes (ChatGPT summary) within the incident: **Sentinel-Incidents-Search (Brute-Force)-Click/Select Brute-Force-On right pane scroll down to "Write a comment" and copy and paste ChatGPT summary and paste it in the rectangular box.**



- Update policies and tools to prevent recurrence.
 - In real life, we would probably make a company policy for hardening the VMs to not allow completely wide open NSGs. This can be done with Azure Policy, but we won't do anything for now. Just acknowledge it

Closure

- Review and confirm incident resolution.
 - Review/observe your notes for the incident.
- Finalize reporting and close the case.
 - Close out the Incident within Sentinel as a "True Positive" because multiple logon attempts and none succeeded.

Part 4: Cleanup (BE EXTREMELY CAREFUL HERE)

In Sentinel → Threat Management → Incidents, filter for closed incidents and delete YOUR incident

In Sentinel → Configuration → Analytics, delete YOUR analytics rule.

Be extremely careful to only delete YOUR Incident and Analytics Rule. Do not screw this up and delete someone else's, because it's possible. **Search by your name to narrow them down if you have to.**